

# Company Scenario & Gap Assessment Context

**Target Organization:** VortexPe Cloud Services India Pvt. Ltd.

**Author:** Junior GRC Analyst (Portfolio Assessment)

**Effective Date:** October 2026

## 1. Company Profile & Business Context

**VortexPe Cloud Services India Pvt. Ltd.** is a fast-growing, cloud-native B2B fintech startup headquartered in Bengaluru, Karnataka, India. The company specializes in building high-throughput payment gateway integration APIs, white-label digital wallet backends, and automated transaction reconciliation software for e-commerce platforms and banking partners.

- **Target Operating Environment:** 100% cloud-hosted infrastructure on Amazon Web Services (AWS Asia-Pacific / Mumbai region, ap-south-1).
- **Core Architecture:** Microservices deployed on containerized Amazon Kubernetes Service (EKS) clusters, backed by managed AWS PostgreSQL databases and S3 object storage repositories.
- **Data Boundary & Sensitivity:** VortexPe processes, stores, and transmits sensitive customer financial records and Personally Identifiable Information (PII)—including PAN cards, government identifiers, customer contact details, and transaction histories—belonging to Indian citizens.

## 2. Why This Gap Assessment Was Conducted

VortexPe is transitioning from an early-stage startup into an enterprise-ready fintech vendor. To sustain its growth and secure key enterprise deals, executive management initiated this formal gap assessment driven by three strategic triggers:

### A. Customer & Enterprise Sales Requirements (Vendor Risk Management)

VortexPe is currently bidding on major enterprise contracts with tier-1 Indian commercial banks and large e-commerce platforms. Enterprise security and procurement teams require VortexPe to demonstrate a mature, auditable security posture and produce a formal **ISO/IEC 27001 Statement of Applicability (SoA)** before approving vendor onboarding.

## B. Mandatory Regulatory Compliance (DPDP Act 2023)

As a Data Fiduciary under the Indian **Digital Personal Data Protection (DPDP) Act 2023**, VortexPe faces strict legal mandates under Section 8 regarding data principal rights, consent enforcement, data minimization, and protection against PII exposure. Executive leadership required a baseline assessment to ensure non-production environments and data pipelines comply with DPDP requirements to avoid severe regulatory penalties.

## C. Preparing for Formal ISO 27001 Certification

VortexPe plans to undergo formal third-party ISO/IEC 27001:2022 certification auditing in Q1 2027. Before engaging an accredited external registrar (PECB/IRCA/BSI), the CISO requested an internal baseline gap analysis against **ISO 27001:2022 (Annex A)** and **NIST CSF 2.0** to identify control deficiencies, evaluate maturity levels, and build an actionable **30-60-90 Day Risk Remediation Plan**.

# 3. Assessment Scope & Evaluated Frameworks

The gap assessment was executed across VortexPe’s core technical, operational, and data processing boundaries:

VortexPe Cloud Scope Boundary:

- AWS Infrastructure (Mumbai Region): IAM, KMS, S3, VPC, GuardDuty, CloudTrail
- EKS Kubernetes Clusters: Microservices, API Gateways, Ingress Controllers
- Data Persistence: Amazon Aurora PostgreSQL (Production & Non-Prod Staging)
- DevSecOps Pipelines: GitHub Repositories, CI/CD Runners, Container Registries

| Evaluated Framework          | Core Focus Areas in Assessment Scope                                                                                                                                                                                               |
|------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ISO/IEC 27001:2022 (Annex A) | Evaluated 10 key control domains including Access Control (A.5.15), Cloud Security (A.5.23), BCP/DR (A.5.29), Vulnerability Management (A.8.8), DLP (A.8.12), Logging (A.8.15), Cryptography (A.8.24), and Secure Coding (A.8.28). |

|                                  |                                                                                                                                                                                           |
|----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>NIST CSF 2.0</b>              | Aligned technical findings across core functional functions ( <i>Govern, Identify, Protect, Detect, Respond, Recover</i> ) to give executive leadership clear risk management visibility. |
| <b>DPDP Act 2023 (Section 8)</b> | Verified PII storage boundaries, data masking practices in non-production environments, and encryption standards for customer financial records.                                          |

## 4. Assessment Methodology (Persona-Based Audit Simulation)

Because this gap assessment was conducted as a practical portfolio demonstration, the discovery fieldwork was structured using a **persona-based audit simulation methodology**:

1. **Persona Definition:** Modeled three distinct technical control owners within VortexPe—a **DevOps Lead**, a **Database Administrator (DBA)**, and a **Lead Software Engineer**.
2. **Discovery Interview Scenarios:** Designed role-specific audit interview scripts probing how access controls, backup handling, deployment pipelines, and environment separation are practically executed.
3. **Condition vs. Criteria Analysis:** Evaluated simulated operational practices against formal control criteria (ISO Annex A clauses and DPDP Act rules) to identify divergence points (control gaps).
4. **Synthesis & Deliverable Package:** Formulated maturity ratings (CMMI Level 0–5), assigned inherent risk scores (*Critical, High, Medium, Low*), and generated the complete 4-part artifact package (README.md, 01\_Gap\_Assessment\_and\_SoA\_Matrix.xlsx, 01\_Company\_Context\_and\_Scope.docx, 02\_Statement\_of\_Applicability.pdf, and 03\_Executive\_Gap\_Analysis\_Report.pdf).